

Post address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(12)

Trygg-Hansa Försäkring branch

Decision following supervision under the
Data Protection Regulation – Trygg-Hansa Försäkring branch
Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (IMY) finds that Trygg-Hansa Försäkring branch (organization number 516403-8662) has processed personal data in violation of Articles 5.1 f and 32.1 of the Data Protection Regulation¹ by failing to implement appropriate technical measures during the period from October 2018 to February 2021, thereby allowing unauthorized access to sensitive personal data concerning its customers. The Swedish Authority for Privacy Protection decides, based on Articles 58.2 and 83 of the Data Protection Regulation, that Trygg-Hansa Försäkring branch shall pay an administrative fine of 35,000,000 (thirty-five million) kronor for the violation of Articles 5.1 f and 32.1.

Description of the supervisory matter

Background

The Swedish Authority for Privacy Protection (IMY) received a tip in December 2020 that Moderna Försäkringar, a branch of Tryg Forsikring A/S (Moderna Försäkringar), had enabled access for unauthorized persons to personal data concerning sensitive information about Moderna Försäkringar's customers. IMY initiated supervision against Moderna Försäkringar in March 2021 to examine whether Moderna Försäkringar had taken appropriate measures to ensure a level of security that was adequate in relation to the risks associated with the processing of personal data, in accordance with Articles 5.1 f and 32 of the Data Protection Regulation.

As part of its review, IMY has examined the 16 documents referred to in the tip. These include several different types of insurance documents, such as claims reports, invoices, insurance policies, insurance decisions, response cards regarding insurance compensation, changes in coverage, and requests for additional information for insurance investigations. The documents contain a large number of categories of personal data, such as names, contact details, health information, personal identification numbers, financial information, insurance holdings, event sequences (for example, time, place, actions, and other information provided by the data subjects in free text fields), and information regarding ownership and property damage.

In April 2022, Moderna Försäkringar merged with Trygg-Hansa. Moderna Försäkringar then changed its name to Trygg-Hansa branch (Trygg-Hansa) but continued to operate under the same organization number as before (516403-8662). IMY will consistently use the new name of the supervisory subject, Trygg-Hansa, in its account of the events that occurred.

Account from the supervisory subject

Trygg-Hansa has mainly stated the following.

On November 30, 2020, Trygg-Hansa was contacted by a person by phone who informed about the deficiency. The recipient of the tip at Trygg-Hansa did not understand that it concerned a possible incident, and the deficiency was therefore not reported further within Trygg-Hansa's organization.

The security deficiency occurred in the following manner:

1. An existing or new potential customer contacted customer service by phone and requested a quote for insurance. After the phone call, the customer service representative sent an SMS or email to the customer.

2. The SMS or email contained a unique web address to a quote page on Trygg-Hansa's website.
3. On the quote page, there were clickable links with web addresses leading to documents with insurance information. The person who contacted Trygg-Hansa as mentioned above was able to open the documents by clicking on the links.
4. These documents had web addresses that could at the time be modified by the person in their browser by replacing numbers with other numbers. In this way, the person could retrieve documents of other customers.

There was access via the internet to information about approximately 650,000 customers during the period from October 2018 until IMY contacted the company at the end of February 2021. The information involved includes names, personal identification numbers, contact details (address, email address, phone number), insurance numbers, claim numbers, financial information, health information, insurance holdings, ownership information (such as pet ownership, vehicle information, property information), property damage (such as information about workshops, compensation notices), event sequences (for example, time, place, actions, and other information provided by data subjects in free text fields) and other free text fields. It cannot be ruled out that information about legal violations (such as in connection with claims reports) or information about membership in a trade union (such as when insurance has been taken out with a trade union) may also have been disclosed.

Analysis of behavioral patterns in logs indicates that 202 customers are likely directly affected in such a way that information about them (documents) may have been shown to an unauthorized person. As far as Trygg-Hansa has been able to ascertain, after reviewing logs, only the tipster and IMY have accessed the documents. To prevent similar security deficiencies from occurring, Trygg-Hansa had taken measures prior to the incident by developing an IT security policy, conducting regular penetration tests, and logging on nodes, transactions, and customer management systems, as well as holding annual training in data protection and security and ongoing...

Swedish Data Protection Authority

Diary Number: DI-2021-1905

3(12)

Date: 2023-08-28

training for employees with special responsibility for data protection issues. Trygg-Hansa follows the ISO 27001 standard, which includes continuous penetration testing and network segmentation. Trygg-Hansa did not conduct a data protection impact assessment regarding the relevant processing before the processing began. However, this would have been carried out if the personal data processing had started today, as Trygg-Hansa now has procedures for this. Since approximately mid-2019, Trygg-Hansa has been implementing a compliance system where Trygg-Hansa systematically describes processes, data, storage, contracts, suppliers, etc., along with impact assessments.

To access documents containing information about other customers, it has, according to Trygg-Hansa, required knowledge of the structure of internet addresses and how to access the underlying content using, for example, a web browser. Furthermore, it has required modification of some of the numbers in the web address's Document ID.

Since the relevant incident was identified, Trygg-Hansa has taken additional security measures, such as addressing the specific deficiency by encrypting and ensuring that access can only be granted to authorized individuals. After the incident was identified, Trygg-Hansa also conducted two independent penetration tests by two different external security companies, updated the IT security policy, implemented measures to improve testing activity procedures, decided to establish an architecture council with security oversight and code review during development, reviewed the internal customer complaint process, and decided to conduct further training for employees in customer service as well as for developers and testers.

Trygg-Hansa has also contacted affected individuals via mail, and in some cases by phone, to inform them about what has occurred and has provided information on its website.

Justification of the decision

Has Trygg-Hansa ensured an appropriate level of security for the personal data?

Applicable provisions

According to Article 5.1(f) of the General Data Protection Regulation, the data controller shall process personal data in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (integrity and confidentiality).

According to Article 9.1 of the General Data Protection Regulation, it is, as a rule, prohibited to process special categories of personal data (so-called sensitive personal data), including data concerning health. Article 9.2 specifies certain exceptions to the prohibition.

Article 32.1 of the General Data Protection Regulation states that the data controller shall implement appropriate technical and organizational measures to ensure a security level that is appropriate in relation to the risk of the processing. This shall, according to the same provision, be done taking into account the latest developments, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, varying in likelihood and severity, to the rights and freedoms of natural persons. In assessing the appropriate level of security,

Swedish Authority for Privacy Protection

Case Number: DI-2021-1905

4(12)

Date: 2023-08-28

according to Article 32.2, special consideration is given to the risks posed by the processing, particularly from accidental or unlawful destruction, loss or alteration, or to unauthorized disclosure of or unauthorized access to the personal data that has been transferred, stored, or otherwise processed. Assessment by the Swedish Authority for Privacy Protection

Trygg-Hansa is the data controller

Trygg-Hansa has stated that it is the data controller for the personal data processing that the tip-off concerned, which is supported by the investigation in the case. The Authority assesses that Trygg-Hansa is the data controller for the processing covered by the supervision.

The processing has involved significant privacy risks and required a high level of protection

The data controller must ensure a level of security that is appropriate based on the risks of the processing. The assessment of the appropriate level of protection must take into account, among other things, the nature, scope, context, and purpose of the processing as well as the risks, of varying likelihood and severity, to the rights and freedoms of individuals. In the assessment, special consideration must be given to the risks posed by the processing, including unauthorized disclosure of or unauthorized access to the personal data.

The Authority notes that the processing of personal data has involved a large number of registered individuals within Trygg-Hansa's core operations. According to Trygg-Hansa's own information, it has concerned data about approximately 650,000 customers.

The Authority further notes that the processing has involved a large number of personal data about each registered individual, which has enabled mapping of individuals' personal circumstances. The 16 documents that the Authority has reviewed in the context of the supervisory case contain a large number of categories of personal data, such as names, contact details, health data, personal identification numbers, financial information, insurance holdings, event sequences (for example, time, place, actions, and other information provided by the registered individual in free text fields), and information regarding ownership and property damage. Trygg-Hansa has also indicated that it cannot be ruled out that information about legal violations or membership in a trade union has emerged.

Through access to one document, it has been possible to directly read a large number of details about an individual person. Thus, in certain cases, it has been possible to obtain a detailed picture of the registered individual's personal circumstances using the documents. The extensive processing of personal data has been particularly sensitive in terms of privacy due to the use of personal identification numbers and other identifying information that has enabled a clear and direct link to individual persons.

The Authority further assesses that the nature of the personal data itself has posed a high risk. The documents have contained sensitive personal data, including health information, which, according to

the main rule in Article 9.1 of the General Data Protection Regulation, may not be processed. Such data has been given enhanced protection, as processing them can constitute a particularly serious infringement of the fundamental rights regarding respect for private life and protection of personal data.² The health data has also had a

2 Judgment of the Court of Justice of the European Union in Case C-184/20, Vyriausioji tarnybinės etikos komisija, EU:C:2019:773, paragraph 126.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-1905

5(12)

Date: 2023-08-28

at a high level of detail, such that it has been possible to discern how a health issue arose or exactly what health condition is involved, which has posed an even higher risk.

The material has also contained other types of information that are particularly worthy of protection. This includes, among other things, information about personal identification numbers that are subject to special protection under Article 87 of the Data Protection Regulation and Chapter 3, Section 10 of the Act (2018:218) on supplementary provisions to the EU Data Protection Regulation. According to Trygg-Hansa, it cannot be ruled out that there have been data regarding legal violations that are subject to strong protection under Article 10 of the Data Protection Regulation, as the processing of such data can have serious effects on individuals. There has also been information regarding individuals' financial circumstances.

The documents in the case also indicate that it has been possible for the registered individuals to provide information themselves in forms. In certain claims reports, the registered individuals have provided detailed information in free text regarding health issues and how injuries occurred. By allowing the opportunity to provide information in free text, Trygg-Hansa has found it difficult to fully control the content and the types of information presented. This has led to specific requirements for handling the documents securely.

Overall, the large number of registered individuals, the extensive amount of information about each person, and the sensitive nature of the data have resulted in a high risk to the rights and freedoms of natural persons. Unauthorized disclosure of or unauthorized access to personal data could lead to serious consequences for the affected individuals. This has necessitated a high level of protection for the processing.

IMY further notes that the context of the personal data processing has imposed an even higher requirement for the level of protection. The processing of personal data has occurred within the framework of Trygg-Hansa's core operations. Furthermore, the registered individuals have legitimate expectations of a high degree of confidentiality and robust protection against unauthorized access to personal data processed in insurance operations. The data has also been collected to enable assessments and decisions regarding the registered individuals, which is a type of personal data processing that can entail higher risks and requires higher protection.

In summary, the processing has been of such a nature that high security requirements have been placed on the data, for example through access control, encryption, logging, access control, and management of technical vulnerabilities.

The data has not been adequately protected.

IMY will then assess whether Trygg-Hansa has ensured the high level of protection required.

IMY notes that it has not been required for those who gained access to the data to verify their identity to Trygg-Hansa or otherwise verify their authorization to access it. Those who have had access to the web addresses have thus been able to visit the websites and thereby gain access to documents containing personal data without it being ensured that the person was authorized. The data in

3 The Council of Europe has stated in a recommendation that member states should ensure that employees in insurance companies who have access to personal data are subject to confidentiality rules (Recommendation rec[2002]9 on the protection of personal data collected and processed for insurance purposes). See also Prop. 2009/10:241 p. 43 and Ds 2011:7.

The documents have not been protected by encryption and have been available in clear text. Furthermore, the information has directly identified individual persons, meaning that the data has not been protected through pseudonymization. Thus, Trygg-Hansa has made a large amount of direct personal data of a sensitive nature available on the internet without taking protective measures in the form of access control or encryption.

Trygg-Hansa has claimed that special knowledge is required to access documents containing personal data via the URLs. However, IMY has observed through the documents and URLs in the case that it has been possible to access the documents by changing the last digits in the URLs. In some cases, the first six digits out of eight have been the same in the different URLs, which means that only a few digits needed to be changed for an unauthorized person to access the documents.

It has also been possible to forward the URLs, which lead to unprotected data about policyholders, to other unauthorized persons. These individuals have, in turn, been able to access the information in the documents simply by clicking on the URL without needing to change any digits. The fact that in some cases an individual had to change digits in the URL field to access the documents does not mean that Trygg-Hansa has taken appropriate measures, such as authentication and access control, to prevent unauthorized individuals from accessing the relevant information.

IMY has been able to access information in the documents without hindrance, merely by visiting the URLs and without needing to modify the address field in the browser.

In light of this, IMY concludes that Trygg-Hansa has made a large amount of sensitive personal data accessible in clear text on the internet. No authentication has been required to ensure that only the correct individuals could access the information. Individuals who have obtained or facilitated unauthorized access to the sent URLs – or manipulated versions of the sent URLs – have thus been able to access the sensitive personal data.

Based on these circumstances, IMY assesses that there have been significant deficiencies in the protection of the data. The investigation also shows that these deficiencies have led to unauthorized access to the data. IMY notes that Trygg-Hansa's own logs indicate that 202 customers have likely been directly affected in such a way that their information may have been displayed to an unauthorized person. However, it should be emphasized that the fact that it has been easy for unauthorized individuals to gain access to a large amount of personal data of this nature is a serious deficiency in itself, regardless of how many instances of unauthorized access have been possible to ascertain.

The deficiencies have been of such a fundamental nature that Trygg-Hansa should have detected and addressed them before the system was implemented. However, Trygg-Hansa has implemented the system with the deficiencies and has not been able to identify and rectify them during the long period that the system was in use. This is despite the fact that Trygg-Hansa received information about the deficiencies through an external tip. IMY further notes that the processing of personal data is part of the insurance company's core operations and that Trygg-Hansa should therefore have had a good ability to ensure a level of security that was appropriate given the scope and sensitivity of the processing.

Overall, IMY assesses that Trygg-Hansa has not taken appropriate technical measures to ensure a level of security that is suitable in relation to the risk. Thus, Trygg-Hansa has processed personal data in violation of Article 32.1 of

Data Protection Regulation. The fact that a large number of personal data, including sensitive data, has been processed for an extended period in a manner that posed a risk of unauthorized access means, according to IMY, that the security deficiency has been of such a serious nature that it also

constitutes a violation of Article 5.1(f) of the Data Protection Regulation.

Choice of Intervention

Legal Regulation

If a violation of the Data Protection Regulation has occurred, IMY has a number of corrective powers available under Article 58.2 of the Data Protection Regulation.

According to Article 58.2 of the Data Protection Regulation, IMY shall impose administrative fines in accordance with Article 83, in addition to or instead of other corrective measures referred to in Article 58.2, depending on the circumstances of each individual case.

Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the Data Protection Regulation.

Article 83.2 specifies the factors to be considered in determining whether an administrative fine should be imposed, as well as what should influence the amount of the fine. Relevant to the assessment of the seriousness of the violation are, among other things, its nature, severity, and duration.

According to Article 83.4, in cases of violations of, among other things, Article 32, administrative fines of up to 10,000,000 EUR or, if it concerns a company, up to 2% of the total global annual turnover in the preceding financial year shall be imposed, depending on which value is higher.

According to Article 83.5, in cases of violations of, among other things, Article 5, administrative fines of up to 20,000,000 EUR or, if it concerns a company, up to 4% of the total global annual turnover in the preceding financial year shall be imposed, depending on which value is higher.

If it concerns a minor violation, IMY may, as stated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2(b) of the Regulation.

IMY's Assessment

Administrative Fine to be Imposed

IMY has assessed that Trygg-Hansa has processed personal data in violation of Article 32.1 and that the violation is of such a serious nature that it also constitutes a violation of the principle of integrity and confidentiality in Article 5.1(f).

The violation has occurred because Trygg-Hansa processed personal data with an insufficient level of security, which has resulted in a risk that unauthorized persons could gain access to approximately 650,000 customers' data during the period from October 2018 to February 2021. The personal data has included sensitive personal data and personal identification numbers, and unauthorized access to this data poses a high risk to the rights and freedoms of the data subjects.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-1905

8(12)

Date: 2023-08-28

IMY does not consider that the violations in question are of a less serious nature. Therefore, Trygg-Hansa shall be imposed an administrative sanction fee for the violations. In determining the amount of the sanction fee, IMY shall take into account the circumstances specified in Article 83.2 and ensure that the administrative sanction fee is effective, proportionate, and deterrent.

The parent company's annual turnover shall be the basis for the calculation.

In determining the maximum amount for a sanction fee to be imposed on a company, the definition of the term "company" used by the Court of Justice of the European Union in the application of Articles 101 and 102 of the Treaty on the Functioning of the European Union (see Recital 150 in the General Data Protection Regulation) shall be applied. The court's case law indicates that this encompasses any entity engaged in economic activity, regardless of the entity's legal form and the manner of its financing, as well as whether the entity legally consists of several natural or legal persons.

What constitutes a company shall therefore be based on the definitions from competition law.

The rules for group liability in EU competition law revolve around the concept of an economic unit. A parent company and a subsidiary are considered part of the same economic unit when the parent company exercises decisive influence over the subsidiary. The decisive influence (i.e., control) can be

achieved either through ownership or through agreements. Case law indicates that a one hundred percent or nearly one hundred percent ownership presumes that control is deemed to exist. However, this presumption can be rebutted if the company provides sufficient evidence to demonstrate that the subsidiary operates independently in the market. To rebut the presumption, the company must provide evidence concerning the organizational, economic, and legal connections between the subsidiary and its parent company that shows they do not constitute an economic unit despite the parent company holding 100 percent or nearly 100 percent of the shares.

Trygg-Hansa constitutes a branch of the Danish company Tryg Forsikring A/S. Tryg Forsikring A/S, in turn, is a wholly-owned subsidiary of Tryg A/S ("Tryg"). According to the presumption described above, it is therefore Tryg's turnover that shall be the basis for calculating the maximum sanction fee amount. To deviate from the presumption, Trygg-Hansa must provide sufficient evidence that another turnover should be the basis for the calculation.

Trygg-Hansa has argued that it is the part of Tryg's turnover corresponding to the turnover of Moderna Försäkringar that should be the basis for calculating the maximum sanction fee. Trygg-Hansa has estimated this turnover to be 2,406,294,859 Danish kroner. In the alternative, Trygg-Hansa believes that the maximum sanction fee should be based on the turnover of Moderna Försäkringar and Tryg, whereby the turnover of the companies acquired by Tryg after the period under review should be excluded from the calculation of the sanction fee. Trygg-Hansa has estimated this turnover to be 23,622,304,333 Danish kroner.

IMY has understood Trygg-Hansa's position to mean that the maximum sanction fee should primarily be calculated based on the hypothetical turnover that the branch Moderna Försäkringar would have had in 2022 if Trygg-Hansa and Moderna Försäkringar had not merged in April 2022. Furthermore, IMY has understood that Trygg-Hansa

4 Case C-97/08, paragraphs 59-61

5 Cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, paragraph 125 and the decisions cited therein.

Swedish Data Protection Authority

Diary Number: DI-2021-1905

9(12)

Date: 2023-08-28

In the alternative, it is considered that it is Tryg in the organization that was applicable when the deficiency existed, in which Moderna Försäkringar is included, that constitutes the economic unit on which a maximum sanction fee should be calculated. In determining the relevant annual turnover for Tryg, the estimated turnover for the companies acquired after the violation date should therefore be excluded.

Trygg-Hansa has summarized its position by stating that Moderna Försäkringar at the time of the review should be seen as an independent operation from Tryg in technical and organizational terms. Trygg-Hansa has primarily highlighted the following. Moderna Försäkringar was a branch solely for tax reasons. Moderna Försäkringar independently determined its actions and had its own management team. The server environment where the relevant personal data processing took place was operated and developed by Moderna Försäkringar, which also had its own IT manager and IT organization. Only customers of Moderna Försäkringar are affected in this matter. The personal data processing reviewed in the case was not sanctioned by Tryg, and the insurance systems for the two operations were different and distinct from each other without any logical, organizational, or technical connection. According to Trygg-Hansa, the turnover of the acquired companies should, in any case, be excluded from Tryg's turnover when determining the maximum sanction amount, as the responsibility for a violation according to competition law practice should be attributed to the entity that had decisive influence over the operation at the time of the incident.

IMY makes the following assessment. Trygg-Hansa is a branch of Tryg Forsikring A/S and is therefore not an independent legal entity. Trygg-Hansa's turnover is included as an integral part of Tryg's total turnover and is fully integrated with the turnover of Tryg Forsikring A/S. These circumstances strongly suggest that Trygg-Hansa, Tryg Forsikring A/S, and Tryg should be regarded as one and the same

economic unit. The circumstances highlighted by Trygg-Hansa regarding the branch, when it was known as Moderna Försäkringar, having its own management team, IT systems, and IT organization do not, in themselves, contradict the notion that it concerns one and the same economic unit. Overall, IMY assesses that there are no grounds to deviate from the presumption that it is Tryg's turnover that should form the basis for calculating the maximum sanction fee.

Regarding Trygg-Hansa's position that the turnover of the acquired companies should be excluded from the calculation of the maximum amount of the sanction fee, IMY makes the following assessment. At the time of the violation, Trygg-Hansa was, as it is today, a branch of Tryg. Thus, no organizational changes have occurred that in themselves affect the liability relationship between the branch and the company. It can further be noted that the fact that the relevant annual turnover in the calculation of the sanction fee is the annual turnover established in the year immediately preceding the supervisory authority's decision may lead to significant changes in annual turnover having occurred since the time of the violation, both decreases and increases. Such changes may be due to business events, such as increasing or decreasing market shares and profitability, or changes in the company's organization, such as sales or acquisitions of companies. There is to some extent the possibility to take such changes into account within the framework of the proportionality assessment that must always be made when imposing sanction fees according to the data protection regulation to ensure that the imposed sanction fee is proportionate in the individual case. However, IMY assesses that the maximum sanction fee amount should be based on the established annual turnover, without deductions for hypothetical amounts for the companies that have been acquired during this time period.

Swedish Authority for Privacy Protection

Case Number: DI-2021-1905

10(12)

Date: 2023-08-28

However, IMY considers both the fact that the violation occurred in a limited part of Tryg's operations and the organizational changes that Trygg-Hansa has highlighted, within the framework of the proportionality assessment, which is detailed below under the heading "The sanction fee must be effective, proportionate, and deterrent."

IMY assesses that the company's turnover that should be used as the basis for calculating the administrative fines that Trygg-Hansa may be imposed is Tryg's turnover. According to Tryg's annual report for the year 2022, the annual turnover in 2022 was approximately 33,938,000,000 Danish kroner, which corresponds to approximately 54,000,000,000 Swedish kronor. The maximum sanction amount that can be determined in this case is four percent of this amount, that is, approximately 2,160,000,000 Swedish kronor.

Severity of the Violation

IMY makes the following considerations regarding the severity of the violation. The existence of a possible unauthorized access to the data of approximately 650,000 customers implies that there has been a risk to a high number of individuals. The data has included sensitive personal information, such as health data, and other information of a privacy-sensitive nature, such as personal identification numbers and financial information. It cannot be ruled out that information about legal violations may have been disclosed. The processing of personal data has involved significant risks. Individual persons have been directly identifiable, which has meant that sensitive information could be linked to identified individuals. The data has been processed in a context where the registered individuals have legitimate expectations of a high level of confidentiality and robust protection against unauthorized access.

The data has been collected to enable assessments and decisions regarding the registered individuals, which is a type of personal data processing that can entail higher risks and requires higher protection. Information about, for example, ownership, which could pose a risk of theft, could easily be linked to names and addresses in the event of unauthorized access. Due to the nature of the data, and since the documents contained multiple aggregated pieces of information, any unauthorized access has posed a high risk of reputational damage and loss of confidentiality. Trygg-Hansa's analysis of behavioral patterns in logs indicates that 202 customers are likely directly affected in such a way that

information about them in documents may have actually been shown to unauthorized persons, and IMY notes that unauthorized access has occurred at least once, in connection with the tip-off about the deficiency provided to IMY.

The violation has also persisted for a longer period, between October 2018 and the time when IMY contacted Trygg-Hansa and pointed out the deficiency in February 2021. Trygg-Hansa received information about the security deficiencies through an external tip in November 2020, which could have been used to address the deficiencies and thereby reduce privacy risks for individuals. However, Trygg-Hansa was unable to use the information to rectify the deficiencies. The violation has concerned Trygg-Hansa's core operations, where Trygg-Hansa can be assumed to have knowledge of the risks and requirements for the protection of personal data.

According to the EDPB's guidelines, the supervisory authority should assess whether the violation is of low, medium, or high severity.

IMY has determined that the violation is so serious that it also constitutes a violation of the fundamental principle of integrity and confidentiality according to Article 5.1 f of the GDPR.

6 Based on the exchange rate on August 23, 2023, published on riksbanken.se

7 EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 60.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-1905

11(12)

Date: 2023-08-28

the General Data Protection Regulation, which means that the maximum administrative fine is 4 percent of annual turnover instead of 2 percent, which applies in the case of a violation of Article 32. IMY assesses that the current violation has a medium severity level within the range of violations of Article 5.1 f of the General Data Protection Regulation.

Trygg-Hansa has taken a number of measures before and after the deficiencies were identified.

Trygg-Hansa has, among other things, conducted two independent penetration tests by two different external security companies and initiated measures aimed at improving the procedures for testing activities. Trygg-Hansa has further decided to establish an architecture council with security control and code review during development, decided to conduct additional training for employees in customer service as well as for developers and testers. Trygg-Hansa has also provided certain information to the data subjects about the incident. However, these and other measures described by Trygg-Hansa were implemented after IMY contacted the company to inform them of the deficiency and do not go beyond what can be expected. The measures are not of such a nature that they affect IMY's assessment in the case in a mitigating direction.

The administrative fine must be effective, proportionate, and deterrent

The administrative fine must be effective, proportionate, and deterrent. This means that the amount must be determined so that the administrative fine leads to correction, that it has a preventive effect, and that it is also proportionate in relation to both the current violations and the financial capacity of the supervisory subject.

In the proportionality assessment, IMY takes into account that Trygg's annual turnover has significantly increased due to the acquisition of companies that were not included in the company's total turnover at the time of the violation.

IMY also attaches great importance to the fact that the violation, as far as has been revealed in the case, occurred solely in the Swedish branch. To base the assessment solely on the group's turnover in this case, where the violation has affected a limited part of the business, would result in the administrative fine being set too high in relation to what has occurred. Therefore, IMY sees reason to determine the administrative fine to a significantly lower amount than what an assessment based solely on Trygg's turnover would have resulted in, taking into account the turnover for Moderna Försäkringar that Trygg-Hansa has reported.

IMY determines, based on a comprehensive assessment, that Trygg-Hansa shall pay an administrative fine of 35 million kronor.

This decision has been made by the Director General Lena Lindgren Schelin after presentation by the lawyer Evelin Palmér. In the final handling, the legal manager David Törngren and the unit manager Catharina Fernquist, as well as the IT and information security specialist Magnus Bergström, have also participated.

Lena Lindgren Schelin, 2023-08-28 (This is an electronic signature)

Swedish Authority for Privacy Protection

Diary Number: DI-2021-1905

12(12)

Date: 2023-08-28

How to appeal

If you wish to appeal the decision, you must write to the Swedish Authority for Privacy Protection. Indicate in your writing which decision you are appealing and the change you are requesting. The appeal must be received by the Swedish Authority for Privacy Protection no later than three weeks from the day you received notice of the decision. If the appeal is submitted in a timely manner, the Swedish Authority for Privacy Protection will forward it to the Administrative Court in Stockholm for examination.

You can email the appeal to the Swedish Authority for Privacy Protection if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.